

# Política de Segurança: Conceitos e Aplicabilidades

**C**onforme estudamos anteriormente um sistema de segurança da informação ou da segurança cibernética, será composto por um conjunto de mecanismos, tecnologias, processos, procedimentos e normas que têm como objetivo garantir a proteção não só de dados e informações, mas também de todos os elementos que compõe os ativos de TI de um ambiente organizacional.

Implementar as tecnologias e mecanismos de proteção em uma infraestrutura de TI dentro de um ambiente organizacional, em tese pode ser considerado uma tarefa até relativamente fácil para as equipes de TI. Isto porque no geral as equipes de TI possuem as expertises necessárias. Porém, fazer com que as áreas de negócio da organização e as pessoas compreendam e exerçam o seu papel junto a segurança da informação e segurança cibernética é sempre uma tarefa mais complexa e difícil. Isto porque, implementar uma mudança de cultura com relação à proteção dos ativos de TI, fazendo com que cada área de negócio e cada colaborador – pessoa – entenda seu papel e sua responsabilidade para com a proteção das tecnologias da informação é um processo que requer muita paciência, dedicação e envolvimento não só das equipes de TI, mas também da alta cúpula administrativa e das demais partes envolvidas. É aí que se encaixam as políticas de segurança da informação.

Mas, afinal o que é uma política de segurança da informação (PSI)? Podemos entender a política de segurança da informação como um conjunto de instruções, normas e regras previamente definidas, revisadas e aprovadas que deverão ser seguidas por toda a organização, a fim de garantir uma boa gestão da segurança.

Uma política de segurança da informação, de acordo com a norma ABNT ISO/IEC 27002:2013 tem como objetivo, prover orientação da Direção e apoio para a segurança da informação de acordo com os requisitos do negócio e com as leis e regulamentos relevantes. Neste sentido, uma PSI deve ser aprovada pela alta administração da organização e, depois repassada para todas as demais áreas organizacionais e respectivamente todos os colaboradores e partes externas relevantes. Lyra (2008) também descreve um objetivo de uma PSI, como o

documento formal que deve fornecer orientações sobre como a organização vai se portar frente à segurança da informação e, neste contexto, caberá a cada organização produzir uma política de segurança da informação específicas a suas necessidades, ameaças, vulnerabilidades e exposição ao risco. Percebe-se aqui que cada PSI deverá ser construída e definida de acordo com as dificuldades e necessidades que cada organização possui com relação a manter suas informações e ativos de TI seguros.

Diante dos conceitos e objetivos apresentados, é evidente que uma boa PSI deve ser criada de acordo com as carências e deficiências na segurança da informação de cada organização e, por ser um documento abrangente que permeia e norteia toda a organização, incluindo em alguns casos partes externas, ela deve ser bem estruturada, analisada e aprovada pela alta administração da organização e, de tempos em tempos de acordo com as estratégias da organização e respectivamente as mudanças ocasionadas por fatores tais como o ambiente em que a organização está inserida, a evolução das ameaças, a revisão dos riscos, novas leis e regulamentações no qual a organização está subordinada e possíveis novas vulnerabilidades ela – PSI, deverá passar um processo de revisão e melhoria contínua.

É importante ressaltar que todos os conceitos apresentados sobre uma política de segurança informação e respectivamente os objetivos são igualmente aplicados a uma política de segurança cibernética, porém com o foco na proteção da informação e de todos os ativos de TI que se encontra no espaço cibernético, ou seja, na Internet, ou em qualquer outro ambiente virtual.

Com relação às características de uma PSI, ela é subdividida em 3 partes, a saber:

- Diretrizes – definidas pela alta administração da organização e devem seguir as estratégias definidas pela cúpula de diretores, acionistas e/ou demais partes interessadas que compõe a alta administração da organização;
- Normas – ocupam o lugar mais tático e, são criadas para nortear os procedimentos e instruções impostos ao nível operacional do ambiente organizacional. No geral podem conter mecanismos legais de sanções e penalizações previstos no estatuto da organização ou de acordo com as leis e regulamentações que a organização deve seguir, caso não cumpridas ou respeitadas.

- Procedimentos e Instruções – se encontram no nível operacional da organização e são destinados a todas as áreas operacionais da organização, incluindo seus respectivos colaboradores. Em alguns casos os procedimentos e instruções podem ser aplicados a partes externas tais como: clientes, fornecedores e parceiros comerciais.

Sêmola (2014) destaca que as diretrizes, normas e procedimentos e instruções devem ser idealizadas conforme os seguintes aspectos: (a) natureza do negócio; (b) cultura organizacional; (c) ativos físicos; (d) ativos tecnológicos e por fim (e) ativos humanos. Já com relação ao número de diretrizes, normas e procedimentos e instruções a serem criadas, estes serão definidos de acordo com as necessidades de cada organização e modelo de negócio.

Por fim, Ferreira e Araújo (2014) acrescentam que com relação à criação de uma boa política de segurança da informação ou cibernética, recomenda-se a formação de um comitê de segurança da informação multidisciplinar. Ou seja, composto por integrantes de diversas áreas da organização, tais como: jurídica, tecnologia da informação, operacional, engenharia, financeiro, além de um membro da diretoria.

### **Dicas para a construção de uma boa Política de Segurança**

A construção de uma política de segurança da informação ou segurança cibernética não é uma tarefa fácil. Isto porque, requer do comitê multidisciplinar de segurança da informação e, em especial da equipe de TI ou segurança da informação, tempo, dedicação, comprometimento e o mais importante conhecimento não só dos ativos de TI, mas também de toda a estrutura organizacional e do modelo de negócio que a organização realiza, incluindo: cultura organizacional, missão, valor e visão da organização, aspectos relacionados a estratégias da organização, dentre outros. É importante ressaltar que por se tratar de um documento interno, durante a sua criação não há o envolvimento de clientes, fornecedores e/ou parceiros comerciais.

Neste contexto, percebe-se que a construção de uma política de segurança da informação é um processo complexo e, sendo assim para facilitar se faz necessário a divisão em quatro etapas, a saber:

Primeira Etapa: Questionário

Elabore um questionário a fim de descobrir todas as informações sobre a organização. A ideia aqui é obter informações sobre o ambiente de negócio da organização, o ambiente tecnológico, compreensão das necessidades e uso dos serviços e recursos de TI pelas áreas de negócio, incluindo os processos que cada área de negócio realiza com o uso das tecnologias da informação.

#### Segunda Etapa: Conteúdos da Política

Aqui é o momento em que você irá descrever na política de segurança da informação os conteúdos pertencentes a ela, tais como: a definição da segurança, objetivos, fatores críticos para o sucesso, atributos relacionados a normas e responsabilidades, áreas de segurança, recursos humanos, classificação e tratamento da informação, processos disciplinares, uso da internet, processos de gerenciamento e monitoramento, processos de homologação/produção, registro de falhas, segurança física, segurança lógica dentre outros...

#### Terceira Etapa: Procedimentos de Segurança

Aqui será necessário realizar uma pesquisa sobre frameworks e melhores práticas em segurança da informação ou segurança cibernética que podem ser aplicadas de acordo com o modelo de negócio e a estrutura da organização. Outros artefatos como criação das diretrizes, regras, normas e padrões também precisarão ser construídos nessa etapa. É importante ressaltar que a participação da alta administração é importante neste momento, pois são eles que possuem o poder decisório com relação às normas, regras e padrões que todas as áreas e pessoas da organização devem seguir.

#### Quarta Etapa: Revisão, Aprovação e Implementação

Agora falta pouco! Nessa etapa é o momento em que a política deverá ser revisada minuciosamente, aprovada oficialmente por parte da alta administração e por fim implementada e divulgada para todas as áreas de negócio, colaboradores e demais partes interessadas. Cabe aqui uma dica: em alguns casos pode ser necessário realizar encontros com as áreas de negócio e colaboradores para explicar, sanar dúvidas e promover o conhecimento. Por fim, por questões de compliance (conformidade) é necessário coletar o “de acordo” de todos os colaboradores com relação ao entendimento e aceite da política de segurança da informação.

## Política de Proteção e Privacidade de Dados

Com o surgimento de leis e regulamentações relacionadas a tratamento de dados pessoais tais como a LGPD – Lei Geral de Proteção de Dados Pessoais e, a preocupação constante e crescente com a privacidade de dados e informações pessoais, as organizações passaram a focar sua atenção na criação de políticas específicas e destinadas ao tema: privacidade de dados.

De acordo com o SERPRO uma política de privacidade de dados é um instrumento de implementação do *privacy by design* <sup>[1]</sup> e, faz parte da estrutura de documentos relacionados à proteção de dados. Seu principal objetivo é prover visibilidade ao tratamento de dados pessoais em um determinado serviço, prestado pela organização e atender princípios estabelecidos na Lei Geral de Proteção de Dados Pessoais – LGPD.

Neste contexto, a política de privacidade de dados é um instrumento fundamental para entender conceitos relacionados ao tratamento de dados pessoais bem como os princípios impostos por parte da LGPD no fornecimento de serviços por parte das organizações que realizam o tratamento de dados pessoais.

Todo o conteúdo de uma política de privacidade de dados pessoais deve ser orientado ao serviço que realiza o tratamento de dados pessoais e a organização responsável em fazê-lo. Por se tratar de uma política voltada para as pessoas, todo o conteúdo descrito deverá ser conciso e de fácil compreensão e acesso às pessoas. Por este motivo muitas organizações dispõem suas políticas de privacidade de dados pessoais em seus sítios institucionais na Internet.

No que se refere ao conteúdo deste documento é necessário que ele possua as seguintes informações: (a) informações sobre a organização e o responsável pelo tratamento de dados pessoais; (b) quais dados pessoais são passíveis de tratamento; (c) finalidade do tratamento dos dados pessoais; (d) a base única do tratamento; (e) prazos relacionados à retenção, atualização e descarte dos dados pessoais; (f) informações referente aos canais de comunicação ou atendimento a cliente para solicitações ou esclarecimento de dúvidas com relação ao tratamento de dados pessoais; (g) se há o compartilhamento e tratamento de dados pessoais realizado por terceiros; (h) os direitos dos titulares dos dados pessoais; (i) informações sobre o envio e o direito de remoção do contato do titular dos dados pessoais em sistemas de

marketing digital ou não; (l) informações sobre o tratamento de dados pessoais por sistemas/aplicativos automatizados, dentre outros.

Por fim, há exemplo das demais políticas (segurança da informação e segurança cibernética) a política de privacidade de dados pessoais também deverá ser aprovada pela alta administração, divulgada a todos os colaboradores, fornecedores, parceiros comerciais e principalmente clientes e, sendo assim é fundamental que essa política seja de fácil acesso. Não podemos esquecer que como qualquer outra política, a política de privacidade de dados pessoais também deverá ser verificada de tempos em tempos e sempre atualizada de acordo com as mudanças da lei, necessidades da organização ou do ambiente a qual faz parte. Essa atualização irá garantir não só a conformidade perante a LGPD, mas também a busca da melhoria contínua.

## **Conteúdo Bônus**

Que tal aprendermos um pouco mais sobre segurança da informação, segurança cibernética e proteção e privacidade de dados na era do conhecimento onde estamos a todo momento acessando e compartilhando dados e informações? Então separei alguns vídeos no Youtube no qual tratam um pouco sobre essas questões.

- A História da Informação

Documentários Ciência.

- CPBR7 – Segurança da Informação: por onde eu começo?

Campus Party Brasil.

## **Referência Bibliográfica**

ABNT NBR ISO/IEC 27002:2013. **Tecnologia da informação – Técnicas de Segurança – Códigos de prática para controles de segurança da informação.** Disponível em: < <https://www.abntcatalogo.com.br/norma.aspx?Q=Q0I4Qy9ISjZqVnpBaEhIb2MzMHUzYmJ3N1h0cnBVVTZLN1g5R2IXSVFEbz0=>>.

FERREIRA, F. N. F.; ARAÚJO, M. T. D. **Políticas de Segurança da Informação - Guia Prático para elaboração e implementação.** Rio de Janeiro: Ciência Moderna, 2008.

LASTRE, H. M. M., ALBAGLI, S. (Org.). **Informação e globalização na era do conhecimento.** Rio de Janeiro: Campus, 1999. 318p.

LYRA, M. R. **Segurança e Auditoria em Sistemas de Informação.** Rio de Janeiro: Ciência Moderna, 2008.

SÊMOLA, M. **Gestão da Segurança da Informação - Uma Visão Executiva - 2 ed.** São Paulo: Elsevier, 2014.

SERPRO. **Como elaborar uma política de privacidade aderente à LGPD.** Disponível:<<https://www.serpro.gov.br/lgpd/noticias/2019/elabora-politica-privacidade-aderente-lgpd-dados-pessoais#:~:text=Para%20tanto%2C%20%C3%A9%20necess%C3%A1rio%20mapear,compartilhamentos%20com%20terceiros%20e%20portabilidade>>

TURBAN, Efraim. RAINER, R. Kelly. POTTER, Richard E. **Introdução a Sistemas de Informação.** – Rio de Janeiro: Elsevier, 2007. – 2ª reimpressão.

[1] Privacy by design ou privacidade desde a concepção é uma abordagem ligada à engenharia de sistemas e que preza pela privacidade do usuário durante o processo de construção/desenvolvimento de uma solução.